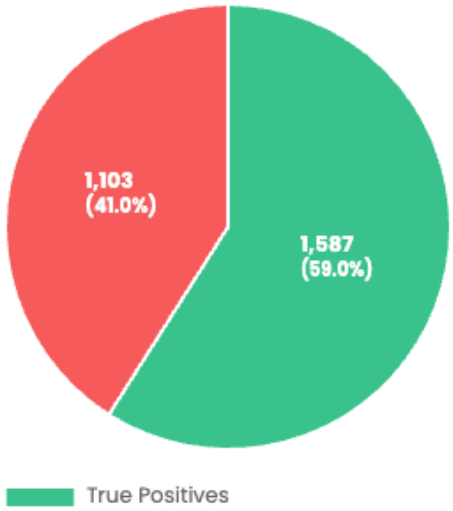
Executive Summary

Static Application Security Testing (SAST) tools are integral to identifying vulnerabilities. But SAST "run" results must be manually triaged to remove false positives, a slow and expensive process that impedes application security, development and delivery. AppSecAI Expert Triage Automation (ETA) automates triage to lower manual triage time, tedium, and costs.

This report details the results from a single SARIF file called OWASP_Benchmark.SARIF.

2,690	1,587	1,103	41.0%
Total Vulnerabilities	True Positives	False Positives	False Positive Rate



Total Cost Savings:	**$50,973**
Manual Process:	$66,238
ETA Process:	$15,265

Total Hours Saved:	**340**
Manual Process:	442 hrs
ETA Process:	102 hrs

Key Findings Analysis: This security assessment revealed 2,690 potential vulnerabilities, with 59.0% confirmed as true positives requiring remediation. The implementation of AppSecAI ETA demonstrated significant efficiency gains, reducing manual triage and documentation time by 77% while maintaining high accuracy. When scaled across 15 repositories, this automation yields potential annual savings of $764,588 and 5,097 labor hours, enabling faster security assessments and more efficient resource allocation.

Detailed Analysis

SAST Test File: OWASP_Benchmark.SARIF

Code Base: https://github.com/OWASP-Benchmark/BenchmarkJava.git

SAST Tool: SemGrep

Triage System: AppSecAI ETA 0.9

Analysis Time: 30 minutes

Total Vulnerabilities: 2,690

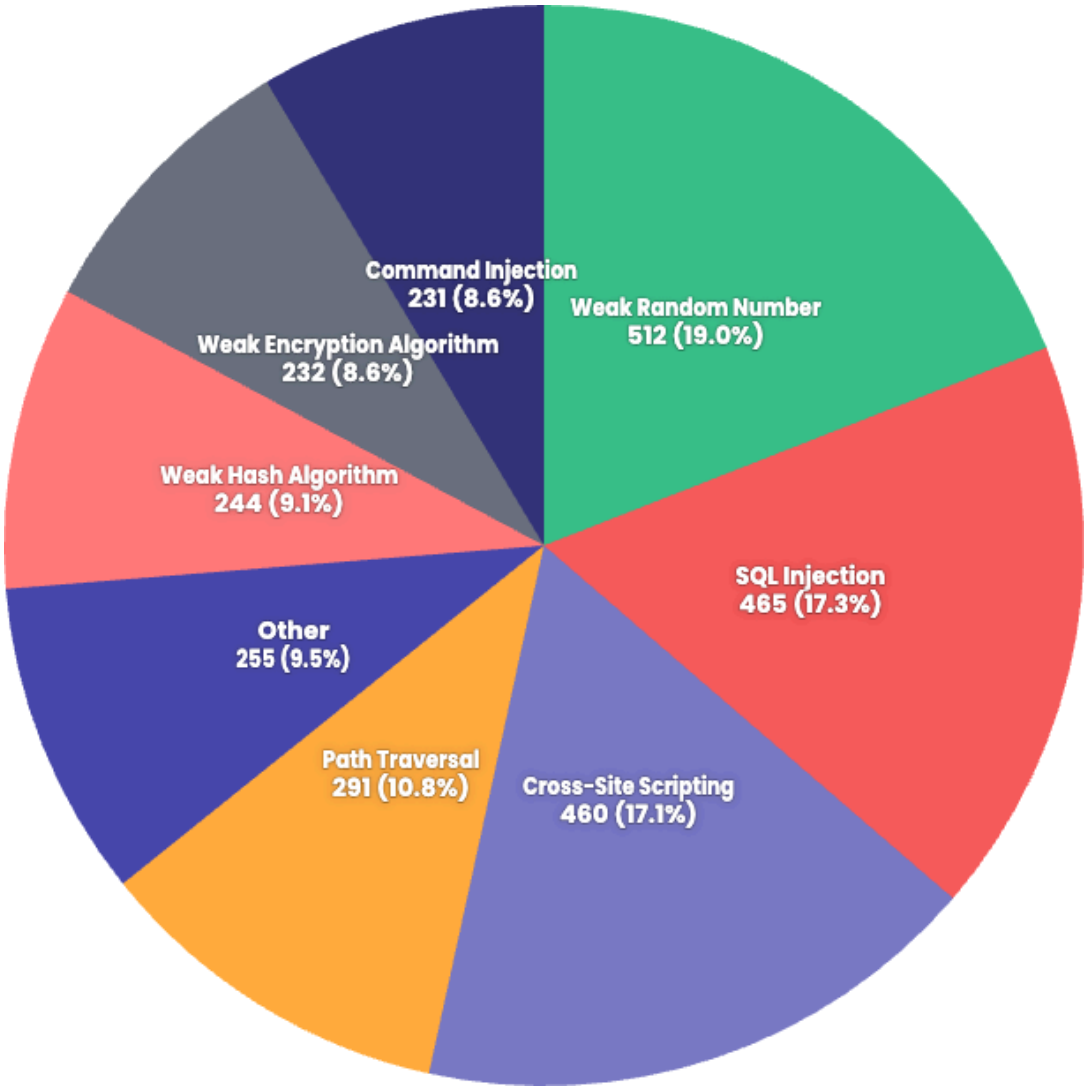
False Positives: 1,103

True Positives: 1,587

False Positive Rate: 41.0%

True Positive Rate: 59.0%

Vulnerability Type Distribution

Vulnerability Distribution Overview

Key Findings Analysis: The vulnerability assessment identified Weak Random Number and SQL Injection as the predominant security concerns, collectively representing a significant portion of all detected issues. Critical analysis of the distribution reveals that 53.4% of vulnerabilities are concentrated in just three categories (Weak Random Number, SQL Injection, Cross-Site Scripting), providing a clear prioritization framework for remediation efforts. This concentration pattern suggests that a targeted security hardening approach, focusing on these primary vulnerability types, would yield the highest security posture improvement with optimal resource utilization.